
Alderman Peel High School Audit Report**Audit Date: 30 January 2020****Report: Year 2 visit 1****DPE: Linda Mortimer****School member: Matt Hardman, Assistant Principal / Ruth Bartram, GDPR Champion****1. Visit details**

Alderman Peel is a small/medium sized high school with 520 students on roll. The school joined the Wensum Trust in 2017 and operates in line with the Wensum Trust's policies. This is the school's first Data Protection Audit carried out by Data Protection Education. The school is aware of its responsibilities regarding compliance with GDPR regulations and the Leadership Team reinforce this through regular staff meetings. Self-audit does take place and the Leadership Team monitors practice across the school. The new GDPR Champion intends to introduce a more formal approach to self-audits and will use the DPE guidance on self-regulation.

During the visit key GDPR documents and policies were reviewed and consideration was given to how the school complies with GDPR requirements. This included DPE Best Practice areas, Record of Processing and Compliance Manager being discussed and demonstrated to the school. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 4 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 3.1 below).

Best Practice Areas on KB: Resources

Policies: DPE advise that Staff should be aware of:

- GDPR Policy and Privacy Notice – all staff including caretaking staff
- Clear Desk Policy – all staff
- Working away from School Policy – all staff that this may apply to
- Breach Procedure – all staff
- Password Policy – all staff
- SAR Procedure – prioritise to LT and senior admin staff
- Photo and Video Guidance – prioritise to LT, Admin, PE, Drama, Head of Year
- Consent – prioritise to LT, Admin, Pastoral
- FOI Policy – LT
- Retention Schedule – Senior admin & LT to have overview – IRMS Toolkit
- DPIA – LT and middle managers

Any of the above policies / guidance and also non GDPR related documents can be shared with staff via the Compliance Manager with 'Read and Understood' and 'Used in Practice' enabled.

Having assigned a document to a member of staff, they are sent an email to say that a document is available to them, that it must be read in a certain timeframe and they must acknowledge receipt.

Best Practice Checklists: These checklists were demonstrated and a sample were completed at the time of the visit. Once actions have been saved, a progress report is immediately shown forming a data dashboard, demonstrating the school's progress with GDPR compliance. This may be a useful report for the school's Leadership Team, GDPR Governor, Local Governing Body or Trust Board.

Record of Processing (RoP): It is a mandatory requirement to map the flow of data which involves personal information. This will be carried out by noting the lawful basis for which it is collected, how data is retained, what safeguards are in place to keep the data secure, where the data is stored, what are the related risks and what mitigating factors are in place to reduce data breaches. This will be mapped using the Record of Processing tool in Knowledge Bank.

DPE recognise that this is a considerable body of work for schools to undertake and therefore the company has been working to prioritise the top 100 most common processes and populate the RoP in a generic format. This will mean that schools will be able to download the generic processes and amend as required, to match their own processes. DPE owns mapping and record of processing for top 100 processes – notes risks, mitigating actions, lawful basis for processing and will include supporting sub-processes

Training: All staff have completed DPE's GDPR 101 online training and this is included in the induction programme for new staff.

There are now 5-10 minute 'learning nuggets' available under the Training section on the Data Dashboard on Knowledge Bank. They include; Password Security, Physical Security, Clear Desk guidance and Data Breaches and SARs. There will be more information available shortly on KB regarding Data Protection Impact Assessments as well as a 20 minute GDPR refresher. The company advises that staff should receive a GDPR refresher every 2 years.

Technical Measures

Website & Prospectus Management: Student images – there are robust systems in place to check for parental permission and there are procedures in place for regular cleansing of student images.

GDPR states that information should be up to date and it is best practice not to retain out of date information eg only retaining a maximum of 12 months newsletters on the school website.

Historical photographs can be kept on a secure area of school server. The school must ensure that access is limited and that the photos are not used for any reason other than the original lawful basis, for which they were collected.

School Server: Located in locked room with limited access. The server is maintained by the school's Data Manager and an effective back-up protocol is in place.

Cyber Essential Questionnaire: This was downloaded at the time of the visit and will be completed by IT Technician. This completed document may be used for reference at the time of completing the RoP.

Cloud Computing & Email Management: Staff use Google Drive and Google Classroom. The Leadership Team has taken the decision not to share student information via Google Documents as there may be inherent security risks.

The Leadership Team are currently trialing Forti Client a VPN to allow access out of school, to the school network as well as SIMS. This new system has proved to be secure, reliable and robust and will be rolled out to rest of the staff shortly.

There is an email protocol in place to protect student identification. Student email communications are monitored by Impero which provides an instant alert to an administrator as well as the pastoral team when key words are used. Alerts are triaged and risk assessed to inform appropriate actions.

Email communication is also monitored for confidentiality and appropriateness. Use tools in SIMS to filter correct contact details to ensure that email addresses are not shared.

Laptops and Use of Laptops away from School: All laptops are encrypted, password protected have virus protection installed and are accounted for on a regular basis.

Staff are reminded regularly about the working away from school policy. This should be provided to all relevant staff and can be shared through Knowledge Bank's Compliance Manager.

Action: Share Working away from school policy via Compliance Manager.

iPads: Are encrypted, password protected and regularly accounted for. These are used by the Leadership Team.

Find my iPad and Return to Factory Settings are installed on these devices.

Student iPads are used for SEND students to access applications and are closely monitored by staff.

Procedures need to be in place to ensure that iPads are regularly cleansed of student images.

Photos can be uploaded to a secure area on the server.

Memory Sticks: The School has software in place on all network computers, which recognises an unencrypted memory stick and triggers automatic encryption to the device.

2.Audit walk and findings on 30.1.20

CCTV: The school has CCTV in place which records directly to the school's main server. The school abides by the Wensum Trust's CCTV Policy.

Action: Check that appropriate CCTV signage is in place – refer to CCTV guidance which can be found on Knowledge Bank. for advice re signage. Ensure that the school operates with a CCTV Viewing Log – example found on Knowledge Bank.

Deputy Headteacher's Office: Noticeboard displaying Year 11 student's predicted grades

Action: Remove surname or cover board when not in use

Main Reception and School Office: The school uses the electronic 'Inventry' visitor signing-in system, therefore minimising the amount of PII data on display to visitors.

PC screens cannot be viewed by visitors.

Lists detailing tutor groups, locations and teacher names were located to a more secure area of the office at the time of the visit.

Actions: Visitors need to be signposted to the location of the Trust's Privacy Notice. The Privacy Notice needs to include a detailed list of third parties with whom PII data is shared.

Files containing FSM, Evolve, medical records and first aid logs are kept in an unlocked cupboard. Please ensure these are stored more securely.

Finance / Exams Office: There is no confidential finance paperwork kept at the school – this is retained at Trust level. Exam papers are kept securely in line with published guidelines.

General Display in Corridors: There are posters detailing Year 11 students' personal achievements which display student photos as well as first name and surname. Permission was gained prior to the printing of the posters.

Action: For future posters, please restrict to first name only.

Other, more general school displays do not include student names.

First Aid/Medical Room: All records are retained in main school office.

Staffroom: Noticeboard displayed lists of students involved in PE events, including first name and surname.

Action: Please revert to either first name only or surname and first initial.

Pigeonholes: Contained some highly confidential information relating to students eligible to FSM, PP and LAC status. Staff data checking sheet including very detailed personal information such as bank account details, NI number etc. Exam entry lists detailing student information.

Action: Reminder to all staff that it is very high risk to leave confidential information in such an area. Reports detailing student FSM, PP and LAC should be locked away at all times. This practice should be ceased forthwith and would constitute a data breach and could result in serious repercussions for staff involved.

School Kitchen: Allergy information is stored on the Cunninghams cashless catering system, therefore no hard copies of allergy information are retained by catering staff.

Pastoral Department: The school uses CPOMS to manage safeguarding paperwork. There were some files on display containing student behaviour reports.

Action: Relocate any files containing student specific reports to a locked cabinet.

SEN Department: Filing cabinets in SENDCo office do not lock. The school is going to use CPOMS to record SEND information, scanning SEN paperwork into the system. Until this is in place existing paperwork must be kept securely.

Action: Please ensure that filing cabinets have working locks.

Cluster SEN Office: Files detailing student access arrangements for exams were on display.

Action: Move files to secure cabinet.

Student Care Plans: Are mostly in an electronic on a secure area of the server. Hard copies are stored in student files which are locked away.

Naming convention: Use of first name only is preferable. However, with the large student numbers the decision was taken that surname with first initial would be more effective. Care to be taken on open evening when consideration should be given when displaying student work and not to include any students where there are safeguarding concerns, care orders or deemed to be vulnerable.

Action: Introduce school-wide naming convention from start of new academic year or earlier if possible – using surname and first initial only.

Management of Printing: Photocopiers should have secure print access enabled – refer to Mark Hardy, Kinoca Minolta to enable this facility. For printing of confidential / sensitive documents, there are a number of areas with dedicated printers to mitigate the risk of data breaches.

Consent: Photo and video guidance is followed. The school ensures that student images are only used for the purpose / lawful basis for which they were originally taken.

Photos can be saved for historical purposes and kept on a secure area of the server.

Actions: Check that the school's consent forms are in line with the DPE model consent documentation.

Share DPE Photo and Video Guidance with staff via Compliance Manager.

Security Levels and Password Protection: School staff understand the reason for security levels required for eg access to the MIS, Attendance and Assessment Software etc.

Action: Share DPE Password Policy with staff via Compliance Manager.

Archiving Arrangements: The current archived records will be assessed for date of disposal in line with the Trust's retention schedule and out of date paperwork will be securely disposed of.

The school uses Data Shred for confidential waste disposal.

For Information: Refer to the IRMS Toolkit for guidance on document retention and disposal timelines.

2. Compliance actions that should now be completed

Initial documents:

- **Privacy Notice - Trust**
- **GDPR Policy - Trust**
- **Data Breach Procedure – share with all staff**
- **SAR procedure – share with relevant staff ie Leadership Team, Senior Admin**
- **Photo and Video consent, guidelines and records – share with staff as relevant**

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd – Trust level
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant – Trust level
- The Privacy Notice, GDPR Policy – Trust level
- Consent withdrawal form should be displayed on the school website; - school level
- All staff should know what the data procedure is, and the document should be circulated to all staff; - school level
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities. – school level

2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. School to refer to the Trusts retention schedule and CE for additional guidance.

3. Next steps

Record of Processing (RoP) tool and data mapping – Trust and School level

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

3.1. Data Protection Impact Assessments (DPIA) – Trust and School level

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

4. Norfolk County Council Summer GDPR audits – Trust and School level

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>